

14. Determine whether ACH activities are considered in the institution's overall business continuity plans and insurance program.
15. Determine whether management monitors originating customers for unreasonable numbers of unauthorized ACH debits. If the volume of unauthorized ACH debits is high, it could expose the institution to greater loss.
16. Determine whether management has addressed international ACH requirements, where applicable.

Objective 9: Assess the quality of risk management and support for electronic banking related retail payment transaction processing.

1. Determine the extent to which the financial institution engages in retail payment systems, including bill payment, prepaid cards, wireless systems, contactless payment devices, remote check capture, lock-box services that provide ACH check conversion or check truncation, and P2P and A2A payments. Consider:

- Strategic plans relating to the introduction of new retail payment system products and services.
- The development of internal pilot programs and partnerships with technology service providers introducing new retail payment systems and delivery channels.
- The extent to which existing Internet and e-banking products and services include new retail payment mechanisms.

2. Evaluate the financial institution's ability to manage the development and implementation of new retail payment services, focusing on effectiveness of internal controls and provisions of consumer compliance regulations. Consider:

- Information security, including identification and authentication systems, in the deployment of any smart cards, wireless payment devices, EBPP, P2P and A2A product offerings.
- Customer disclosure and compliance information for retail payment systems using new technologies.
- Technical resources to effectively manage retail payment systems including Internet technologies, telecommunications protocols, and operations support.

3. Evaluate the financial institution's ability to incorporate new retail payment product offerings into its existing retail business lines and its effectiveness in including these product offerings in its traditional retail payment operations. Consider:

- The integration of new retail payment product offerings into existing clearance,

settlement, and accounting functions.

- Whether the financial institution relies on technology service providers for some or all of these services.

Objective 10: Assess the quality of risk management and support for checks.

1. Determine whether the accounting department handles check return item processing appropriately, reconciling all aged items.

2. If the institution offers its customers RDC services, review the appropriateness of:

- Due diligence procedures for new and existing retail customers.
- Due diligence procedures for new and existing third-party processing customers (ensure processors perform adequate due diligence over their originating retail customers).
- Underlying contracts for:
 - Assignment of liability in the event of returned, disputed, or fraudulent items.
 - Limitations or reasonable parameters regarding activity volumes, including returns.
 - Ongoing transaction activity monitoring procedures.

3. Determine whether the institution uses electronic check presentment (ECP) for payment. If yes, determine:

- The effectiveness of the financial institution's ECP implementation, including logical access controls over electronic files storing MICR and related information.
- Whether the financial institution is using positive pay.
- Whether the logical access controls over the electronic files sent by commercial businesses are adequately controlled.

Objective 11: Assess the quality of risk - management of new and emerging technology risks.

1. Determine the institution's processes for evaluating and deploying new and emerging technologies for retail payment systems. Of particular concern are retail payment products and services that do not use established networks such as ACH, or that extend operational processes to the customer location, as with RDC. Determine:

- Whether the institution conducts risk assessments prior to deployment of new and emerging technologies.
- Whether the processes involve the institution's compliance functions, including consumer compliance, BSA/AML, GLBA 501(b), and third party requirements (for example, NACHA, MasterCard, and Visa).
- Whether risk assessment and compliance status are communicated to senior management and the board of directors.

2. Assess the vendor management program over the technology service providers offering new and emerging technologies for retail payment systems. Determine:

- The adequacy of due diligence performed on the technology service provider.
- Whether management regularly reviews the financial status of the technology service provider.
- Whether management receives independent audits, third-party review, or data information security reviews performed on the technology service provider.
- Whether the information exchanged with the technology service provider is documented and meets the bank's requirements.
- Whether the dispute resolution process between the technology service provider and customer is documented and meets the bank's requirements.
- Whether MIS received from the technology service provider is adequate.

CONCLUSIONS

1. Determine the need to conduct Tier II procedures for additional validation to support conclusions related to any of the Tier I objectives.

2. From the procedures performed, including any Tier II procedures performed:

- Document conclusions related to the quality and effectiveness of the management of the retail payment systems function.
- Determine and document to what extent, if any, the examiner may rely upon retail payment system procedures performed by internal or external audit.

3. Review your preliminary conclusions with the examiner-in-charge (EIC) regarding:

- Violations of law, rulings, regulations, and third-party agreements.
- Significant issues warranting inclusion as matters requiring board attention in the report of examination.
- Potential impact of your conclusions on the Uniform Rating System for Information Technology (URSIT) composite and component ratings.
- Where necessary, communicate relevant conclusions to the EIC for the BSA/AML, or retail credit, or compliance examinations.

4. Discuss your findings with management and obtain proposed corrective action, within reasonable timeframes, for significant deficiencies.

5. Document your conclusions in a memo to the EIC providing report-ready comments for all relevant sections of the FFIEC report of examination (ROE) and guidance to future examiners.

6. Organize work papers to ensure clear support for significant findings and conclusions.

TIER II OBJECTIVES AND PROCEDURES

Examination Objective: The Tier II Retail Payment Systems Examination Procedures provide additional validation steps to verify the effectiveness of a financial institution's internal control processes over ACH, EFT/POS network, check item, electronic banking-related retail payments, and bankcard processing, clearance, and settlement. These procedures assist in achieving examination objectives, and examiners may use them in their entirety or selectively, depending upon the scope of the examination and the need for additional verification.

Examiners should coordinate this coverage with other examiners involved in assessing the institution's information systems, operations, information security, business continuity planning, and vendor management effectiveness to avoid duplication of effort and to ensure there is an adequate understanding of the control environment as it pertains to retail payment business lines.

The procedures provided in this section should not be construed as requirements for control implementation. The selection of controls and control implementation should be guided by the risk profile of the institution. Therefore, the controls necessary for any single institution or any given area may differ from those noted in the following procedures.

The Tier II Retail Payment Systems Examination Procedures provide additional validation procedures verifying the effectiveness of a financial institution's internal control processes over ACH processing, EFT/POS network processing, check item processing, electronic banking-related retail payments processing, and bankcard processing, clearance, and settlement. These procedures assist in achieving examination objectives, and examiners may use them in their entirety or selectively. Examiners should coordinate this coverage with other examiners involved in assessing the institution's information systems, operations, information security, and vendor management effectiveness to ensure there is an adequate understanding of the control environment as it pertains to retail payment business lines and to avoid duplication of effort.

A. EFT/POS and Bankcard Agreements and Contracts

1. If the financial institution is a participant in a shared EFT/POS network or if it contracts with third-party bankcard-issuing or -acquiring processing service providers, determine whether:

- Contracts with regional EFT/POS network switch and gateway operators and bankcard processors clearly set forth the rights and responsibilities of all parties, including the integrity and confidentiality of customer information, ownership of data, settlement terms, contingency and business recovery plans, and requirements for installing and servicing equipment and software.
- Adequate agreements are in place with all technology service providers supplying services for retail EFT/POS and bankcard operations (plastic cards, ATM equipment and software maintenance, ATM cash replenishment) that clearly define the responsibilities of both the service provider and the institution.
- Agreements include a provision of minimum acceptable control standards, the ability of the institution to audit the technology service provider's operations, periodic submission of financial statements to the institution, and contingency and business recovery plans.
- Contracts and agreements clearly define responsibilities and limits of liability for both the customer and financial institution and include provisions of the Electronic Funds Transfer Act (Regulation E) and the Expedited Funds Availability Act (Regulation CC) for deposit activities.

2. Determine whether management periodically reviews individual sites providing retail EFT/POS and bankcard services to ensure policies, procedures, security measures, and equipment maintenance requirements are appropriate.

3. For retail EFT/POS and bankcard transaction processing activities contracted to third-party service providers, assess the adequacy of the review process performed by management regarding annual financial statements, audit reports, and Payment Card Industry (PCI) Data Security Standard assessment.

B. Personal Identification Numbers (PINs)

1. Assess staff access to PIN data. Ensure there is separation of duties between staff responsible for card operations and staff responsible for preparing or issuing bankcards.

2. Assess the adequacy of the PIN generation process. Ensure there is separation of duties between staff responsible for PIN generation and staff responsible for opening accounts or with access to customer account information.

3. For new PIN issuance, assess the adequacy of control procedures including accountability assigned to staff initiating such transactions.

4. Assess the adequacy of PIN generation and issuance procedures to determine whether they preclude matching an assigned PIN to a customer's account number or bankcard.
5. Assess the adequacy of threshold for PIN access attempts to customer account information and funds. The threshold parameter should be set at a reasonable number of unsuccessful attempts.
6. Assess the level of PIN encryption when stored on computer files or transmitted over telecommunication lines.
7. If resets are allowed, assess the adequacy of procedures and controls for PIN/password resets. The use of single-use and temporary PIN/password is preferred.
8. Assess the adequacy of procedures for prohibiting PIN information from being disclosed over the telephone.
9. Assess staff access to PIN-related databases and determine if management restricts access to authorized personnel. Assess database maintenance activities to ensure management closely supervises and logs staff access.
10. Assess the adequacy of customer PIN selection criteria, focusing on whether the institution discourages or prevents customers from using common words, social security numbers, sequences of numbers, or words or numbers that can easily identify the customer.

C. Information Security

1. Evaluate the logical and physical security controls to ensure the availability and integrity of production retail payment systems applications. Determine:
 - Whether the physical and logical security controls established for retail payment transaction processing, clearance, and settlement services maintain transaction confidentiality and integrity.
 - Whether physical controls limit access to only those staff assigned responsibility for supporting the operations and business line centers processing retail payment and accounting transactions.
 - Whether physical controls provide for the ability to monitor and document access to all retail payment operations facilities.
2. Evaluate the effectiveness of all logical access controls assigned for staff responsible for retail payment-related services. Determine:
 - Whether management bases controls on separation-of-duties principles routinely implemented for the processing of financial transactions.
 - Whether management bases access controls on a need-to-know basis.

- Whether management bases assigned access to retail payment applications and data on functional staff job duties and requirements.
- Whether identification and authentication schemes include requiring unique logon identifiers with strong password requirements.
- Whether displayed credit and debit card account data are partially masked to prevent full account numbers from being copied.
- Whether network servers are satisfactorily hardened against the risk of internal or external hacking.
- Whether servers simply used for data storage are unnecessarily connected to the Internet.
- Whether sensitive customer information stored electronically is encrypted; if so, at what encryption level.
- Whether internal audit or other third-party have conducted a security review.

3. Evaluate the security procedures for periodic password changes, the encryption of password files, password suppression on terminals, and automatic shutdown of terminals not in use.

4. Assess whether the institution encrypts telecommunications lines used to receive and transmit retail customer and financial institution counterparty data. If not encrypted, evaluate the compensating controls to secure retail payment data in transit. Assess whether any connecting technology service provider's networks used to transport transactions are transporting transaction data in the clear (not encrypted) or use weak forms of encryption.

5. Assess whether merchants use sufficient encryption for wireless sales terminal activity transmitting sensitive customer information.

6. Assess whether customer information being stored is beyond that required by industry standards.

D. Card Issuance

1. Assess bankcard issuance activities, and review control procedures. Determine whether management:

- Issues bankcards only as requested.
- Periodically inventories bankcards.
- Maintains adequate controls for activating new accounts.

2. Assess effectiveness of the dual control procedures for blank card stock in each of the encoding, embossing, and mailing steps.

3. Assess adequacy of physical access controls for card encoding areas. Management should allow access to authorized personnel only.
4. Assess whether inventory controls for plastic card stock make them physically secure.
5. Assess whether management restricts the use of bankcard encoding equipment to authorized personnel only.
6. Assess adequacy of procedures for issuing cards from more than one location (e.g., branches) to ensure there are accountability and bankcard control procedures at each card-issuing location.
7. Assess adequacy of institution card-mailing procedures. Ensure the institution mails the card and associated PIN to customers in separate envelopes. Also ensure that the return address does not identify the institution.
8. Assess whether mailing procedures provide for a sufficient time between the card and PIN mailings.
9. Assess adequacy of returned card procedures. Determine whether adequate controls are in place to ensure returned cards are not sent to staff with access to, or responsibility for, issuing cards.
10. Assess whether there is appropriate follow-up to determine whether the correct customer received the card and PIN.
11. Assess the adequacy of control procedures (e.g., hot card lists and expiration dates) to limit the period of exposure if a card is lost, stolen, or purposely misused.
12. Determine whether the institution destroys captured and spoiled cards under dual control and maintains records of all destroyed cards.
13. Assess whether the institution adequately controls test or demonstration cards.
14. Assess whether management maintains satisfactory controls over the issuance of replacement or additional cards to the customer (e.g., temporary access cards issued to the customer).
15. Assess the adequacy of the vendor management program to determine whether the institution reviews card issuance services contracted to third parties for compliance with appropriate bankcard control procedures.

E. Business Continuity Planning

1. Assess the adequacy of the financial institution's business continuity plans for a partial or complete failure of each retail payment system. Determine whether the plans include:
 - Recovery of all required components linking the institution with third-party network switch, gateway, or related third-party data centers and bankcard processors.
 - Information relative to the volume and importance of the retail payment system activity to the institution's overall operation.
 - Provisions for acceptable store and forward procedures to protect against loss or

duplication of data and to ensure full recovery within reasonable timeframes.

- Provisions for secured transport and off-site storage of sensitive customer information.
- Stand-in arrangements with other financial institutions, allowing for interim bankcard processing in the event of an outage.
- Adequate testing of plans accounting for various recovery scenarios.

F. EFT/POS and Bankcard Accounting and Transaction Processing

1. Assess the adequacy of reconciliation processes for general ledger accounts related to bankcard and debit card transaction processing activity. Determine whether:

- Accounting reconciles bankcard and ATM transaction activities daily.
- Retail payment system supervisory personnel periodically review reconciliation and exception item reports.
- Accounting periodically reconciles accounts used to control rejects, adjustments, and unposted items.

2. Assess the adequacy of the daily settlement process for institutions participating in shared EFT/POS networks or gateway systems.

3. Assess the adequacy of transaction reconstruction procedures. Transaction files should be duplicated or otherwise retained for a minimum of 60 days, as required by Regulation E, in order to identify unauthorized transactions.

4. Assess the adequacy of the investigative unit in place to address customer inquiries and control non-posted items, rejects, and differences. Management should periodically receive aging reports that list outstanding items.

5. Assess the adequacy of separation of duties for the bankcard and EFT/POS account posting process including receipt of transactions, file updates, adjustments, internal reconciliation, preparation of general ledger entries, posting to customers accounts, investigations, and reconciliation with third-party service provider network switches and card processors.

6. Assess the effectiveness and accuracy of the adjustment process (e.g., changes to deposits and reversals) relating to retail EFT/POS and bankcard transactions processed by staff.

7. For institutions involved in bankcard issuing or acquiring services, determine whether the institution has established:

- Proper accounting controls for the balancing, settling, and reconciliation of all bankcard and acquiring accounts under its control.

- Appropriate credit and liquidity risk measures for the bankcard and acquiring business lines.
- Appropriate controls for the processing of customer or merchant transaction flows.

G. EFT/POS Operational Controls

1. Assess the effectiveness of personnel responsible for internal ATM processing. Determine whether there are:

- Controls prohibiting staff members who originate entries from processing and physically handling cash.
- Proper control of all source documents (e.g., checks for deposit) maintained throughout the daily processing cycle relative to:
 - Input preparation,
 - Reconciliation of item counts and totals,
 - Output distribution, and
 - Storage of the instruments.

2. Determine whether terminal and operator identification codes are used for all retail ATM and POS transactions.

3. Assess the adequacy of controls in place to prevent customer charges from exceeding the available balance in the account or approved overdraft lines.

4. Assess the adequacy of access controls for terminals used to change customer credit lines and account information.

5. Determine whether retail EFT equipment keyboards or display units are properly shielded to avoid disclosure of customer IDs or PINs.

6. Determine whether receipt issuance ensures customers receive a receipt showing the amount, date, time, and location for retail EFT transactions in compliance with Regulation E.

7. Assess whether each retail EFT transaction is assigned a sequence number and terminal ID to provide an audit trail.

8. Assess whether the institution regularly updates hot card or customer suspect lists and distributes them to branch banking locations.

9. Assess the adequacy of verification procedures for telephone-initiated payments or transfers and ensure confirmations are promptly sent to customers and merchants.

10. Assess the adequacy of security devices and access control procedures for EFT/